



Key  **biz v2.2**

보안 정책서

RAON
SECURE



Copyright 2022. Raonsecure Co., Ltd. all rights reserved.

제작날짜 : 2022년 02월 04일

주 소 : 서울시 강남구 테헤란로 145 (역삼동 우신빌딩 13F - 18F)

대표전화 : 02-561-4545

홈페이지 : www.raoncorp.com

문서 승인

버전	작성일	변경내용	작성자	승인자
2.1.0	2019.11.01	최초 등록	박현석	박현우
2.2.0	2021.02.05	Key# crypto 재검증으로 인한 문서 변경, 리눅스 지원 운영환경 변경	정보름	강인규
2.2.1	2021.05.30	Key# biz v2.2 검증 범위 축소로 인한 문서 변경	정보름	박수정
2.2.2	2021.08.23	문구 오류 수정, 내용 수정 및 추가	정보름	박수정
2.2.3	2022.02.04	22.01.19 시험 요청 사항 반영	정보름	박수정
2.2.4	2022.04.25	수정 요청 사항 최종 반영	박수정	박수정

목 차

1. 암호 모듈 특징	5
2. 암호모듈 명세	5
2.1. 암호 모듈 유형	5
2.1.1. 검증 대상 암호 알고리즘	6
2.1.2. 내부 사용 알고리즘	6
2.2. 암호모듈 구성	6
2.3. 검증 대상 동작 모드	6
2.4. 암호 경계	8
3. 암호모듈 인터페이스	9
4. 역할, 서비스 및 인증	10
5. 소프트웨어 보안	11
6. 지원 운영환경	11
7. 물리적 보안	12
8. 중요보안 매개변수 관리	12
9. 자가시험	12
10. 생명주기 보증	13
11. 기타공격에 대한 대응	13
12. 보안정책 및 사용 지침	14
12.1. 보안정책	14
12.2. 사용지침	14

1. 암호모듈 특징

라온시큐어(주) 의 Key# biz v2.2 (이하 'Key# biz' 또는 '암호모듈')는 보안이 취약한 상태로 정보의 전달이 이루어지는 네트워크 환경 및 구간암호화 등의 서비스에 ECDH 기능을 제공하는 암호모듈이다. ECDH 기능 외에 난수 생성, 해시, 무결성 검증 기능 등은 검증 필 암호모듈을 사용한다.

본 암호모듈은 C 기반 동적 라이브러리 형태로 제작 되어 다양한 응용프로그램에 폭 넓게 적용될 수 있다. 하드웨어 및 펌웨어 기반이 아닌 순수 소프트웨어 라이브러리만으로 구성되어 있다.

Key# biz v2.2는 시험기준(KS X ISO/IEC 19790:2015, KS X ISO/IEC 24759:2015)의 보안 수준 1을 만족한다.

시험영역	보안등급
암호모듈 명세	1
암호모듈 인터페이스	1
역할, 서비스 및 인증	1
소프트웨어/펌웨어 보안	1
운영환경	1
물리적 보안	N/A
비침투 보안	N/A
중요 보안매개변수 관리	1
자가시험	1
생명주기 보증	1
기타 공격에 대한 보증	1

[표 1] 보안등급

2. 암호모듈 명세

본 암호모듈은 키 교환을 수립을 위하여 ECDH 알고리즘을 지원하는 암호모듈(이하 '암호 라이브러리')이다.

2.1. 암호 모듈 유형

본 암호모듈은 C 언어로 개발된 동적 라이브러리 형태의 소프트웨어 모듈이다. 동적 라이브러리 형태로 패키징되어 있다. 응용 프로그램에서는 해당 API를 호출함으로써 본 모듈의 코드를 실행시킬 수 있다. 또한, 본 암호모듈은 적용된 알고리즘 외에 비검증 알고리즘을 지원하지 않는다.

2.1.1. 검증 대상 암호 알고리즘

본 암호모듈은 구간 암호화 기능을 지원하기 위해 P-256기반 ECDH 알고리즘을 지원한다. ECDH의 표준은 ISO/IEC 11770-3 Information technology - Security techniques - Key management - Part 3 : Mechanisms using asymmetric techniques (2015)를 근거로 하고 있다. 관련 표준에서 제안하는 Key Agreement Mechanism 중 ECC 기반 Key agreement mechanism 4를 지원한다.

2.1.2. 내부 사용 알고리즘

본 암호모듈에서 사용하는 난수, 해시, 무결성 검증 알고리즘은 KeySharpCryptoV1_4 라이브러리를 사용한다. 암호 연산을 위한 Key# crypto의 정보는 다음과 같다.

- 검증 암호모듈 명칭 : Key# crypto v1.4
- 검증번호 : CM-180-2026.1
- 보안등급 : 보안수준 1
- 효력만료일 : 2026.01.20

2.2. 암호모듈 구성

본 암호모듈의 구성요소 목록은 다음과 같다.

구성요소		설명
Windows	Linux	
KeySharpCryptoV1_4.dll	libKeySharpCryptoV1_4.so	검증필 암호모듈 (ECDH 라이브러리에서 난수생성, 해시, 무결성 검증(RSA-PSS)등 암호 알고리즘 기능 호출시 사용)
bizcrypto_ecdh.dll	libBizcrypto_ecdh.so	ECDH 라이브러리

[표 2] 암호모듈 배포 패키지 구성

2.3. 검증 대상 동작 모드

검증대상 동작모드를 실행하기 위해서는 암호모듈 인터페이스를 호출한다. 암호모듈에서 지원하는 인터페이스에 대한 상세한 설명은 3장 암호모듈 인터페이스를 참조한다.

본 암호모듈은 검증대상 알고리즘만을 지원한다. 하나의 함수에서 입력되는 매개변수에 따라 수행되는 알고리즘이 달라진다.

본 암호모듈에서 제공하고 있는 알고리즘의 종류 및 검증대상 여부를 나타내면 다음과 같다.

기능	알고리즘	용도	제공 모듈
해쉬 함수	SHA-256	무결성 검증	KeySharpCryptoV1_4.dll
서명 알고리즘	RSA-PSS 키 길이 : 2048 (Key# biz에서 SHA256 사용)	무결성 검증	KeySharpCryptoV1_4.dll
난수 발생기	표준번호 : TTA.KO-12.0190 표준제목 : 결정론적 난수 발생기 -제2부- 해시 함수 기반 난수 발생기 HASH_DRBG (SHA256)	개인키 생성	KeySharpCryptoV1_4.dll
키 설정 알고리즘	ECDH (P-256)	검증대상	bizcrypto_ecdh.dll

[표 3] 적용 알고리즘

암호모듈 내부에 암호알고리즘 라이브러리를 탑재하고 있으나, 외부에서는 호출하지 않는다.

본 암호모듈에서 사용하는 Key# crypto (KeySharpCryptoV1_4.dll / libKeySharpCryptoV1_4.so) 와 ECDH 라이브러리 (bizcrypto_ecdh.dll / libBizcrypto_ecdh.so)는 검증대상 동작모드로만 작동한다.

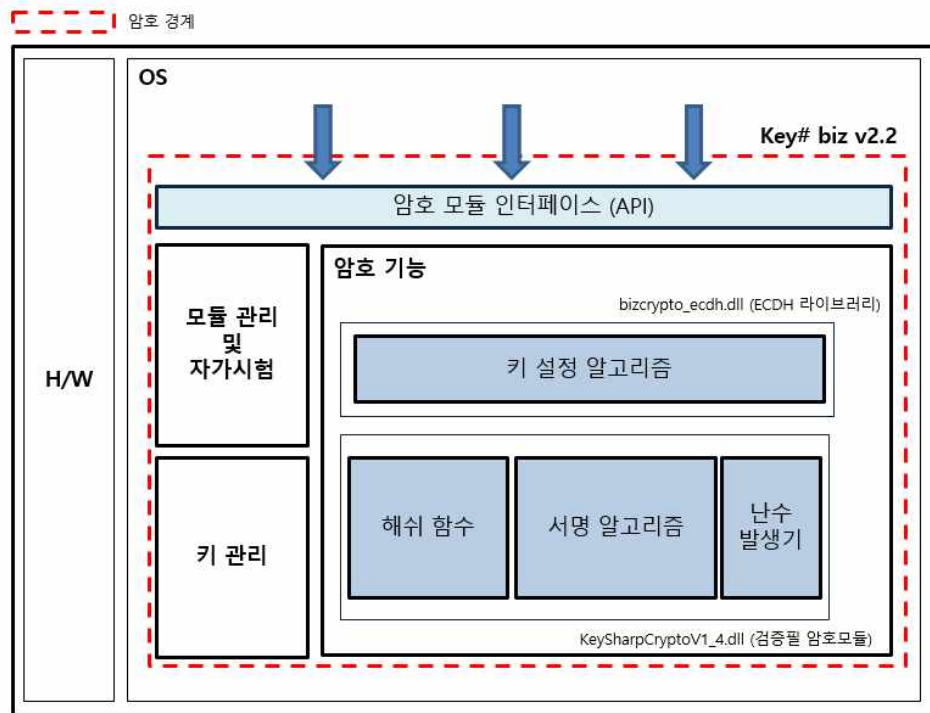
2.4. 암호 경계

본 암호모듈은 외부 구성요소가 존재 하지 않는, 소프트웨어 라이브러리 구성요소만으로 이루어져 있다. 암호모듈의 하드웨어 구성요소와 소프트웨어 구성요소는 다음과 같다.

가) 하드웨어 구성요소 : 본 암호모듈이 저장되고 실행되는 PC 컴퓨터 시스템 본체이다. 이때 컴퓨터 본체는 마이크로 프로세스, 하드 디스크, 메모리 및 운영체제와 같이 본 암호모듈의 수행에 필요한 완전한 하드웨어 및 운영체제 소프트웨어 요소를 가지고 있다.

나) 소프트웨어 구성요소 : 본 암호모듈의 기능을 제공하는 하나의 소프트웨어 라이브러리이다. 본 암호모듈은 C 언어로 작성된 라이브러리이다.

하기 그림은 이러한 암호 모듈 경계를 표현한다.



[그림 1] 암호 모듈 통합 경계

3. 암호모듈 인터페이스

API 호출을 통한 입/출력(데이터입력, 데이터출력, 제어입력, 상태출력) 인터페이스 정보이다. 구성된 API 인터페이스는 직접적인 구성요소의 API 호출을 제한한다. 본 암호모듈은 암호 응용 프로그램의 API 호출 및 해당 함수 매개변수, 리턴 값 등을 입출력 인터페이스로 가진다.

인터페이스	논리적 인터페이스	물리적 포트
데이터 입력	API 호출 시 함수 인자를 통해서 모듈에서 사용될 데이터가 모듈로 전달	키보드, 마우스, 네트워크 포트, 직렬/병렬/USB 포트
데이터 출력	API 호출 시 명시된 결과 값을 받을 함수 인자 혹은 리턴 값을 통해 출력 값이 전달	모니터, 네트워크 포트
제어 입력	API 호출 시 모듈 시작/종료, 암호 운영, 상태 변화를 위한 제어가 전달	키보드, 마우스, 네트워크 포트
상태 출력	API 호출 시 리턴 값을 통해 전달	모니터, 네트워크 포트

[표 4] 모듈 포트와 인터페이스

4. 역할, 서비스 및 인증

본 암호 모듈은 복수 운영자가 아닌 단일 운영자로 지원하고 있으며, 역할은 논리적으로 사용자와 암호 관리자로 구분 할 수 있다. 각 역할에 관한 상세한 설명은 다음과 같다.

- ✓ 사용자: 본 암호 모듈에서 제공하는 서비스에 접근할 수 있는 주체를 말한다. 사용자 역할은 본 암호 모듈에서 제공하는 API를 호출하여 서비스를 이용하는 것이다.
- ✓ 암호 관리자: 본 암호 모듈을 컴퓨터 시스템에 설치하고 운영체제를 설정하며, 본 암호 모듈의 서비스를 사용할 수 있는 주체이다. 암호 관리자는 사용자의 모든 서비스에 접근 가능하나, 키 혹은 데이터에 특별히 접근할 수 있는 권한이 없다. 본 암호 모듈을 설치하고 운영체제를 설정하는 역할을 가진다. 본 암호 모듈은 단일 운영자만을 지원하며, 운영자는 운영체제의 접근 권한 설정을 이용하여 인가되지 않은 접근 시도를 차단한다.

본 모듈이 제공하는 서비스를 역할별로 구분한 내용은 다음과 같다.

해당 역할	서비스 종류	세부 내용
암호 관리자	일반	상태 관리, 버전조회, 자가진단
암호 관리자 / 사용자	키 관리	개인키, 공개키, 키 쌍 관리
암호 관리자 / 사용자	비 대칭키 기능	매개변수 관련, 키 설정

[표 4] 역할 별 인가된 서비스

또한, 본 암호모듈에서 제공하는 서비스는 아래 표와 같다.

모듈	서비스 종류	알고리즘	세부 내용
Key# biz v2.2	일반	ECDH (P-256)	상태 관리, 버전조회, 자가 시험
	키 관리	ECDH (P-256)	개인키, 공개키, 키 쌍 관리
	비 대칭키 기능	ECDH (P-256)	매개변수 관련, 키 설정

[표 5] Key# biz v2.2 서비스 종류 별 알고리즘 정보

5. 소프트웨어 보안

본 암호 모듈은 소프트웨어 무결성을 검사하기 위해서 2048 비트 길이의 RSA 전자서명을 이용한다. 이때 사용되는 RSA-PSS 서명 알고리즘은 검증 대상 알고리즘이다. 해시 알고리즘 또한 검증 대상인 SHA-256이다.

암호 모듈의 무결성 시험이 완료되면 무결성 시험 과정에서 생성된 중간 값들은(공개키 변수, 무결성 검증버퍼 등) 모두 제로화 된다. 암호 모듈이 무결성 실패하는 경우, 심각한 오류로 상태 천

이 되며 제로화를 수행한다. 또한, 서비스 사용이 불가능한 상태가 된다.

본 암호모듈의 무결성 코드 검증절차는 다음과 같다.

단계 1. 윈도우는 시스템 지원 API로, 리눅스는 RC_CM_PATH 환경변수 정보를 이용하여 암호모듈의 PATH 정보를 얻는다.

단계 2. 해당 경로의 암호모듈 읽기를 수행하여 무결성 검증 대상 부분과 260바이트 무결성 정보를 추출한다.

단계 3. 260 바이트 내의 헤더를 체크하고 코드 내에 정의된 RSA공개키(2048bits)를 이용해서 단계 2에서 추출한 무결성 검증 대상과 무결성 정보에 대한 RSA-PSS 전자서명 검증을 수행한다.

단계 4. 중간 값에 대한 제로화를 수행 후 검증 결과에 따라 상태천이를 수행한다.

6. 지원 운영환경

본 암호모듈에서 지원하는 운영환경은 다음과 같다.

구분	설명
운영체제	Windows 10 Pro (64bit)
	Ubuntu 16.04.6 LTS (64bits)

[표 6] 지원 운영환경

7. 물리적 보안

본 암호모듈은 소프트웨어로만 구성되어 있고, 어떠한 형태의 물리적인 직접적인 접근도 불가능하며, 어떠한 형태의 물리적인 유지보수 인터페이스를 가지고 있지 않다.

따라서, 물리적 보안은 전적으로 본 암호모듈을 사용하는 플랫폼에 의존한다.

8. 중요보안 매개변수 관리

본 암호모듈은 암호 알고리즘 연산에 필요한 암호키와 암호모듈의 동작에 필요한 중요 보안 매개변수의 생성, 설정, 저장, 제로화 등의 전체 생명주기를 관리한다.

본 암호모듈의 중요보안매개변수는 함수의 매개변수를 통해 전달되므로 모듈 내에 별도로 저장되지 않는다.

유형	중요보안매개변수		생성	설정	주입	출력	저장	제로화
키설정	CSP	비밀키	O	X	X	X	X	O
	CSP	공유키	X	O	X	X	X	O
	PSP	공개키	O	X	X	X	X	O

[표 7] 중요보안매개변수 관리

9. 자가시험

본 암호 모듈은 동작 전 자가시험과 조건부 자가시험을 통해 검증대상 알고리즘의 바람직한 동작을 확인할 수 있다.

자가시험 구분	자가시험 항목		수행 시점	수행 여부
동작 전 자가시험	핵심 기능 시험	암호 알고리즘 시험	- 암호 모듈 초기화 API 호출 시 ECDH KAT 수행	○
	소프트웨어 무결성 시험		- 암호 모듈 초기화 API 호출 시 암호모듈 무결성 검증 수행	○
조건부 자가시험	암호 알고리즘 자가 시험	기지 답안 시험(KAT)	- 암호 알고리즘 자가시험은 동작 전 자가시험의 암호 알고리즘 시험으로 수행	○
	암호 키 쌍 일치 시험		- ECDH 키쌍 생성 시 생성된 키 쌍에 대한 유효성 검증 수행	○
주기적 자가시험 (사용자 요청)	핵심 기능 시험	암호 알고리즘 시험	- 사용자 요청에 의해 자가시험 API를 호출하면 동작 전 자가시험과 동일한 내용이 수행	○
	소프트웨어 무결성 시험			○

[표 8] 자가시험 구분

10. 생명주기 보증

본 암호모듈은 인가된 운영자에게 배포되며 문서에 명시된 방법으로 설치, 초기화 및 시동을 실행한다. 배포 및 운영 방안은 다음과 같다.

본 암호모듈은 자사 솔루션 등에 탑재되는 형태로 내부 라이브러리로 운용된다. 별도의 물리적 패키지 형태로 제작되어지지 않으며 제품 배포 담당자는 배포관리 시스템 내에 무결성 서명이 완료된 암호모듈 패키지 파일을 업로드 하고 배포 이력을 관리한다. 배포관리 시스템은 자사 내부 배포 관련 내역 관리를 위한 용도로만 사용된다. 배포 과정에서의 참여자는 암호모듈 개발자, 배포 담당자, 정보보호 담당자이며 상세한 역할은 아래 표를 참조한다.

구분	역할
암호모듈 개발자	무결성 생성 작업이 완료된 암호 모듈과 관련 산출물 패키징 완료 후 제품 배포 담당자에게 전달
배포 담당자	자사 암호모듈 필요 요청에 따라 전달받은 암호모듈 패키지를 배포 및 관리를 수행
정보보호 담당자	암호모듈이 보안 USB등에 담겨 오프라인으로 이동이 이루어지는 경우에만 일련의 과정을 관리 감독

[표 9] 제품 관리 인력체계

배포되는 암호모듈을 취득한 관리자는 안전한 장소에 설치하여야 한다. 성공적으로 암호모듈이 설치되는 경우, 암호모듈을 운영하기 위해서 별도의 초기화 과정이 필요하지 않다.

11. 기타공격에 대한 대응

본 암호모듈은 Timing Attack의 대응 방법으로서 Montgomery ladder Method를 적용하였다. 더불어 버퍼 오버플로우를 유발 할 수 있는 함수 사용을 배제하였다.

12. 보안정책 및 사용 지침

12.1. 보안정책

Key# biz v2.2는 KS X ISO/IEC 19790:2015의 보안수준 1을 만족하는 암호모듈로서 다음과 같은 보안 규칙을 만족한다.

- 1) 역할은 논리적으로 사용자와 관리자로 구분된다.
- 2) 암호모듈은 자체적인 인증 방법을 제공하지 않는다. 대신 본 암호모듈을 사용하기 위해서는 운영체제에서 제공하는 인증을 거쳐야만 한다.
- 3) 동작 전 자가시험은 성공 시 암호 서비스를 사용할 수 있고, 실패 시 심각한 오류 상태로 천이한다.
- 4) 암호모듈이 자가시험 중이거나 오류 상태에서 데이터 출력은 금지된다.
- 6) 암호모듈은 CSP 또는 암호모듈의 보안에 문제가 될 수 있는 정보를 출력하지 않는다.
- 7) 암호모듈의 데이터 입출력은 암호모듈에서 정의된 데이터 입력/출력 인터페이스를 통해 수행된다.
- 8) 키설정을 위한 키 쌍 생성은 암호모듈이 제공하는 키쌍 생성 API(검증대상 난수발생기 기반 키쌍 생성)를 사용해야 한다. 단, 외부에서 생성한 키쌍을 사용할 경우 표준에 의거하여 안전하게 생성해서 사용하여야 하며, ASN.1 인코딩을 적용하여 사용해야 한다.
- 9) 핵심보안매개변수는 암호 서비스가 종료되는 시점에 자동으로 제로화를 수행한다.

12.2. 사용지침

Key# biz v2.2의 사용자 및 관리자는 본 문서 및 사용자 매뉴얼에 따라 암호모듈을 사용해야 한다. 암호모듈의 설치에 적절한 플랫폼을 마련하여 진행하며, 테스트 프로그램을 구동하여 설치의 적절성을 검증한다.